SBC · VCFO SUITE · LEGAL REVIEW · 10 NOVEMBER 2026

Is VCFO Assist legal? The picture in one look.

A visual summary of the research report `VCFO Assist legal review`: the extension that fills MCA forms, the AI that helps it, the laws that apply, where you could get stuck, and what to do by when.

Q1 · EXTENSION FILLING MCA FORMS

Looks legal, with conditions

Your own login, human pace, a person signs, submits and pays. MCA's published terms do not ban such tools.

Q2 · REAL CLIENT DATA TO ANTHROPIC

Not safe yet

Ask VCFO sends client facts to the US without client consent. That is already a CA confidentiality problem.

All 24 activities reviewed, by verdict

4
Allowed
Do it.

8
Allowed with conditions
Do it, if the conditions hold.

5
Needs legal opinion
Treat as "no" until a CS says yes.

7
Prohibited
Never. The extension blocks its five by design.

The two real risks

1. The certifier's signature. Every punishment found was for signing something untrue, never for the software. ICAI removed a CA for **120 days** (Feb 2026) for dummy phone numbers in mandatory fields.

2. Ask VCFO. Client facts go to Anthropic in the US. Names, addresses and phones are not masked. No client consent is on file.

The key dates

Now — CA confidentiality · IT Act and SPDI Rules · CERT-In 6-hour reports and 180-day logs · Companies Act · Aadhaar Act

20 Nov 2026 — Decide Ask VCFO's use of client data

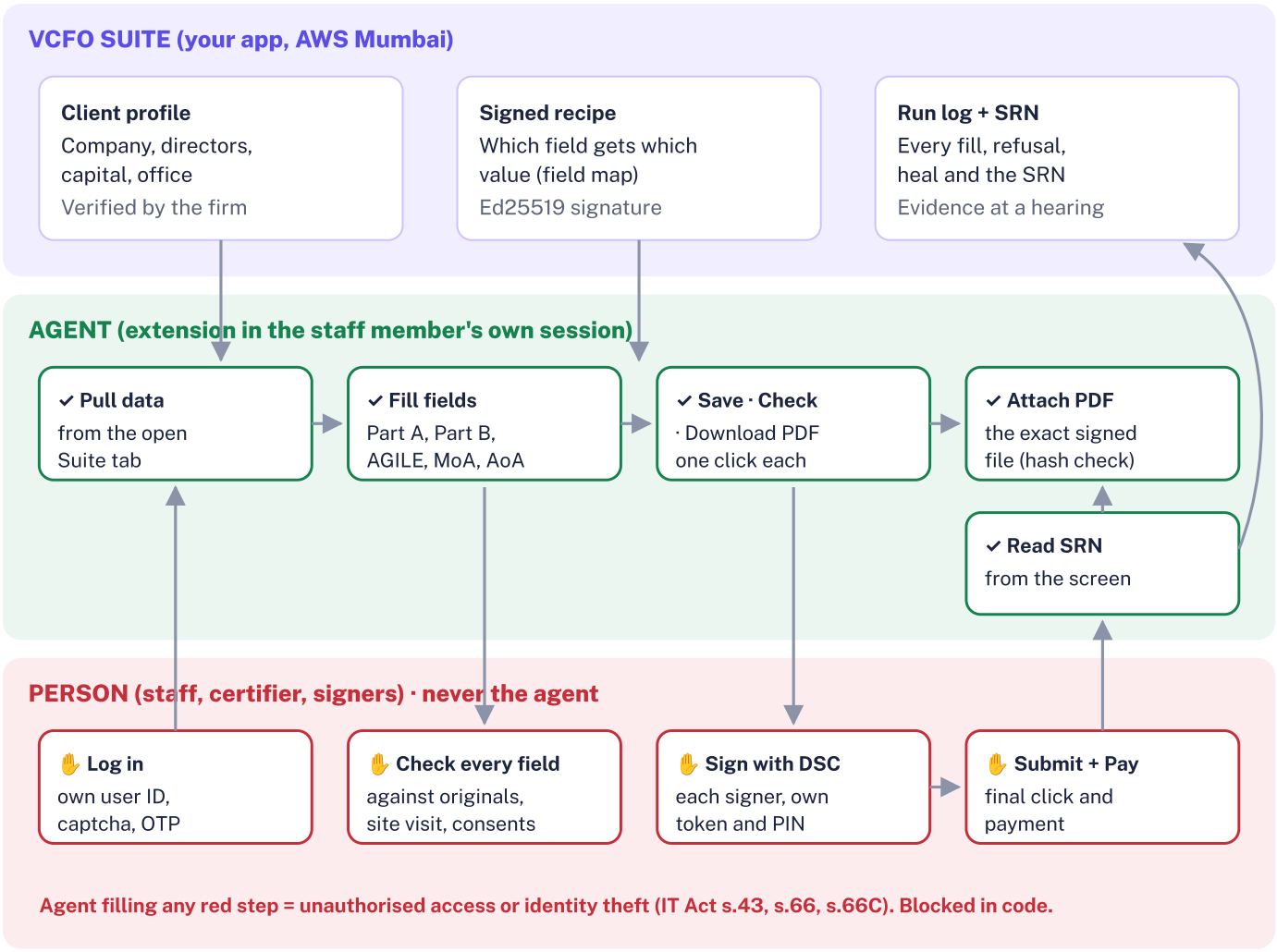
~13 May 2027 — Most DPDP duties start. Penalties up to ₹250 crore.

Research, not legal advice. Built from desk research and a read-only review of the firm's code. mca.gov.in blocked access, so MCA's terms come from an official 2018 copy. A practising CS or advocate must confirm every verdict in writing **before any live MCA use** and **before Ask VCFO handles real client data**. Under SBC's own rule, anything unclear counts as prohibited.

QUESTION 1

Who does what in one SPICe+ filing

Green steps are legal for the agent to do. Red steps stay with a person, by law. The line between them is what keeps the tool legal.



✓ Agent may do · Conditions apply · ✋ Person only

The order, step by step

1. **Person** logs in with their own ID, captcha and OTP.
2. **Agent** pulls the client profile and the signed recipe.
3. **Agent** fills the fields, then saves, checks and downloads the PDF.
4. **Person** checks every field against the originals.
5. **Each signer** signs with their own DSC.
6. **Agent** attaches the exact signed file.
7. **Person** clicks Submit and pays.
8. **Agent** reads the SRN and saves it with the run log.

Conditions on every green step

- A person is present and starts each fill.
- No retry loops; back off on errors.
- **Never a dummy value** in a mandatory field.
- No bulk or unattended runs.
- Only the firm's own clients, only verified records.
- Written CS sign-off before any live use.

Sources: MCA Website Policies (2018 copy); IT Act via India Code; CCA DSC custody rules

QUESTION 1 · DETAIL

Verdict for each extension act

The 17 acts the review checked, colour-coded. The coloured bar on the left shows the verdict.

1	Staff logs in with own ID and types captcha and OTP	Person	Allowed
2	Fill SPICe+ Part A from VCFO Suite data	Agent	With conditions
3	Fill Part B, AGILE-PRO-S, e-MoA, e-AoA	Agent	With conditions
4	Click Save draft and Check form	Agent	With conditions
5	Download the PDF of your own form	Agent	With conditions
6	Each signer signs with own DSC in emBridge	Person	Allowed · required
7	Attach the signed PDF the user drops in	Agent	With conditions
8	A person clicks final Submit and pays	Person	Allowed · required
9	Read the SRN and status from the screen	Agent	With conditions
10	Fill login, captcha or OTP, or solve a captcha	Agent	Prohibited
11	Use a client's or director's MCA ID, or share an ID	Anyone	Prohibited
12	Staff or the agent apply a signer's DSC	Anyone	Prohibited
13	Call MCA endpoints directly or replay requests	Agent	Prohibited
14	Unattended, batched or high-rate runs, data harvesting	Agent	Prohibited
15	Fill the firm's own email or phone as the company's	Agent	Legal opinion
16	Fill values read by AI or OCR without a field check	Agent	Legal opinion
17	Use the same tool on GST, Udyam, DGFT or state portals	Agent	Legal opinion

The conditions behind every blue row

- A person is present and starts each fill.
- Every value comes from verified client records. **Never a dummy value** in a mandatory field.
- No retry loops; back off on errors.
- The certifier checks the filled form against originals before signing, and the check is logged.
- A written CS sign-off exists before live use.

Why the GST portal is different

GSTN's terms allow access **"only through the interfaces expressly authorised by GSTN"** and call scraping an offence. MCA's terms have no such clause; their only automation rule targets **"unusually high numbers of daily database accesses"**. So each new portal needs its own review.

Sources: MCA Website Policies; ICAI DC/1891/2024; GSTN notice via TaxHeal; MCA V3 and ICSI FAQs

QUESTION 2

Where client data goes when AI is used

Two AI features, two very different risks. The field-matching AI sends labels only. Ask VCFO sends real client facts.

TODAY · production

🇮🇳 **VCFO Suite**
AWS Mumbai
Ask VCFO chat

→

🇺🇸 **Anthropic API**
"global" processing
no India option

What leaves India:

× Names, addresses, emails, phones (not masked)
✓ PAN, Aadhaar, passport, DIN masked
× "Do" requests reach the model unmasked
× Kept up to 30 days (flagged: up to 2 years)
× No client consent on file

Real client data here: treat as PROHIBITED

TARGET · Bedrock India

🇮🇳 **VCFO Suite**
AWS Mumbai
Ask VCFO chat

→

🇮🇳 **Bedrock India**
Mumbai + Hyderabad
"in." model IDs

What changes:

✓ Data stays in India, logs in Mumbai
✓ Anthropic never sees prompts (AWS only)
✓ Retention set to "none"
✓ Not used for training
! Still needs client consent + AWS DPA

Allowed WITH CONDITIONS · needs code change

AI activity verdicts

Field-matching AI (labels only), any provider	With conditions
Ask VCFO on public knowledge only	Allowed
Ask VCFO, client data, Anthropic API, **no consent**	Prohibited
Ask VCFO, client data, Anthropic API, consent + DPA + ZDR	Legal opinion
Ask VCFO, client data, Bedrock India, consent	With conditions
Full Aadhaar numbers or images to any AI	Prohibited
AI-read ID documents into portal fields, no check	Legal opinion

Why it is a problem today, not in 2027

CA Act, Second Schedule, Part I, Clause (1): disclosing client information "to any person other than his client ... without the consent of his client" is professional misconduct. In force now.

SPDI Rules (IT Act s.43A): transfers of sensitive data need consent or necessity. In force until ~May 2027.

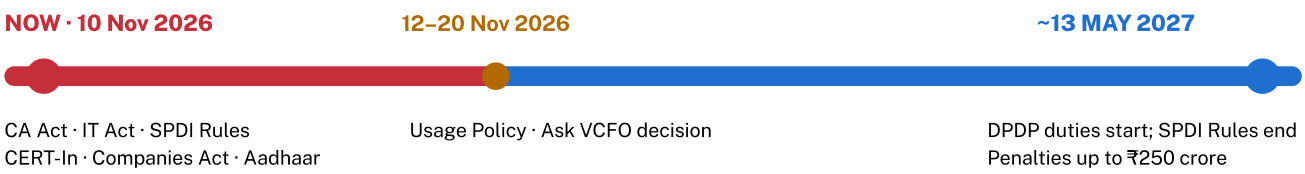
Anthropic Usage Policy (from 12 Nov 2026): personal legal or tax advice is high-risk. A qualified person reviews the answer first, and the person is told AI was used.

Sources: firm code review (infra/app.tf, src/lib/ask/*); Anthropic Commercial Terms, DPA, data residency docs, Usage Policy; AWS Bedrock data protection and India CRIS (29 Sep 2026)

QUESTION 3

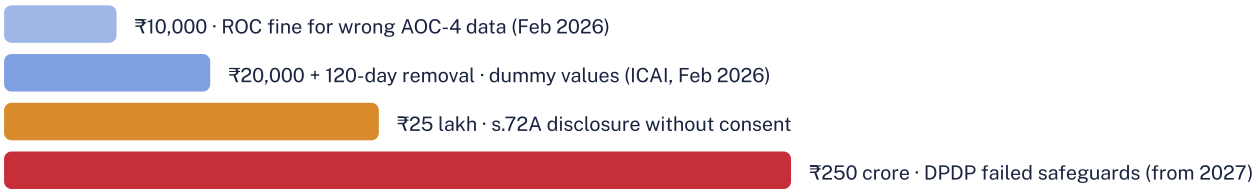
Which laws apply, from when, and what they cost

Most new data-protection duties start in May 2027. But five sets of rules already apply today.



LAW	WHAT SBC MUST DO	IN FORCE	MAXIMUM PENALTY
CA Act + ICAI / ICSI duties	Client confidentiality. Due diligence before certifying. DSC owner keeps custody.	Now	Reprimand, fine, removal (120 days seen)
Companies Act 2013	True particulars (s.7). Personal certification on INC-8 / INC-32.	Now	s.448 → s.447: **6 months–10 years** jail, up to 3× amount
IT Act s.43, 66, 66C, 70	No access without permission. Never use another person's password or signature.	Now	s.66: 3 yrs / ₹5 lakh · s.66C: 3 yrs + ₹1 lakh
IT Act s.72A	No disclosure of personal data obtained under contract without consent.	Now	Civil penalty up to **₹25 lakh**
IT Act s.43A + SPDI Rules 2011	Reasonable security for sensitive data; consent before transfer.	Now → May 2027	Compensation to the person harmed
CERT-In Directions 2022	Report incidents in **6 hours**. Keep logs **180 days**. Sync clocks. Name a contact.	Now	s.70B(7)
Aadhaar Act 2016	Use only for the stated purpose. Never display publicly. Store masked only.	Now	Not verified
DPDP Act 2023 + Rules 2025	Director notice and consent. Processor contracts. Safeguards. Logs 1 year. Breach notice in 72 hours.	~13 May 2027	**₹250 cr** safeguards · **₹200 cr** breach notice · **₹50 cr** other

The penalty ladder, smallest to largest



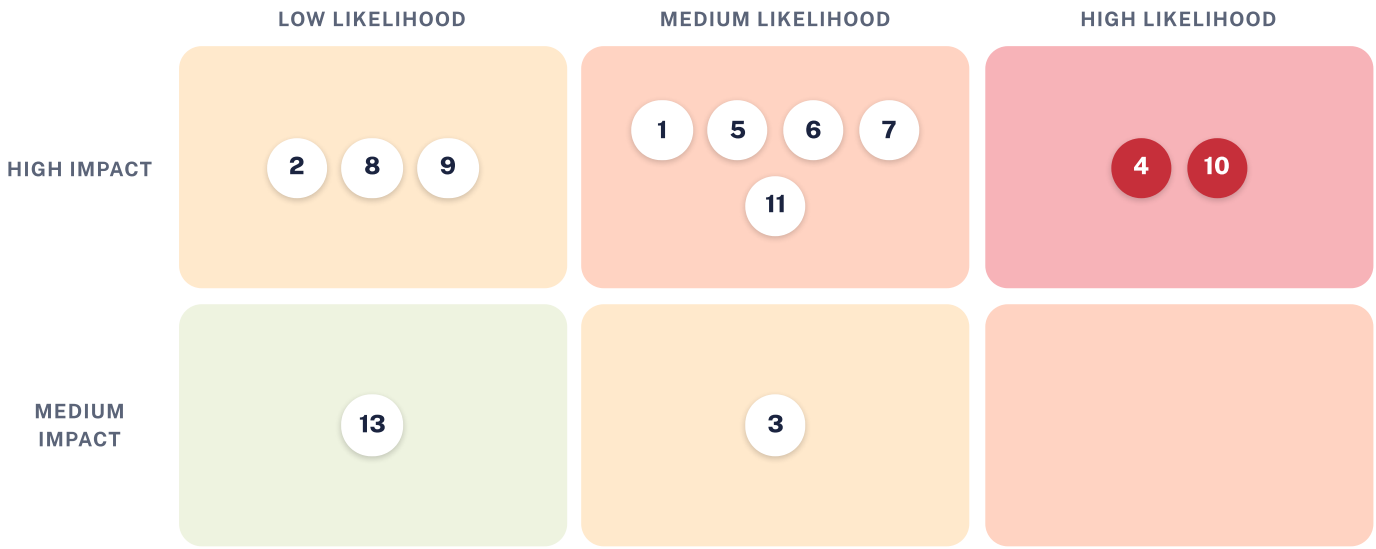
Bars show order of size, not to scale. Jail terms (s.447, s.66, s.66C) sit outside this ladder and need intent or dishonesty.

Sources: India Code (IT Act); ca2013.com (s.447); CERT-In FAQs; DPDPA.com (Rules, Schedule); AZB & Partners; KSK; Khaitan & Co; AdvocateKhoj (CA Act)

QUESTION 4

Where you could get stuck

Thirteen ways it could go wrong, placed by how likely they are and how much they would hurt. Fix the top-right first.



#	HOW IT GOES WRONG	REAL EXAMPLE	CONTROL
4	**Ask VCFO sends client facts to Anthropic without consent**	ICAEW warning (2024)	Pause or get written consent; move to Bedrock India
10	**Director data has no lawful basis on 13 May 2027**	—	Director notice + consent in the client questionnaire
1	Certifier ticks "personally visited" because the tool was fast	Bansal, reprimanded 2025	Due-diligence gate before the Submit card
5	Staff use someone else's session or DSC	Puneet Jain, reprimanded	One ID per person; DSC register; log device and IP
6	A hijacked extension update steals sessions	Cyberhaven, Dec 2024	Force-install, pinned updates, 2-person release
7	Ransomware hits; the 6-hour CERT-In report is missed	I4C alert on CA firms, 2026	Incident runbook with three clocks
11	Processor contracts missing in May 2027	—	DPAs with AWS, Anthropic, Resend, Inngest
2	The tool fills a dummy value to pass a mandatory field	Gubiligari, 120 days, 2026	Guard: never fill a value missing from source
8	Live MCA V3 terms turn out to bar automated tools	None found	CS reads the live terms first
9	MCA21 is notified as a "protected system" (s.70)	None found	Watch the Gazette; pause if notified
3	A mapping or AI heal error puts a wrong value in a filing	ROC ₹10,000, 2026	Review table; second check on AI-healed fields
13	A test run is pointed at the live portal	—	Live switch stays off; mock-only tests
12	Insurer refuses a claim tied to automation or cyber	Wording not found	Written insurer confirmation; cyber policy

Sources: ICAI DC/1720/2023, DC/1891/2024; TaxGuru; Taxscan; TechCrunch (Cyberhaven); I4C alert; ICAEW

WHAT TO DO

The action plan, by date

Eighteen actions, grouped by deadline. Owners: Owner (managing partner), CS, Dev, Super admin, Office.

Now · ongoing

- Keep the live-portal switch off until the written CS opinion — Super admin

Before 20 Nov 2026

- Decide Ask VCFO's use of real client data; until consent, limit it to non-client knowledge — Owner
- "AI was used" notice + mandatory CA/CS review of AI answers on a client's legal or tax position — Dev, Owner
- Send the updated CS questions; CS reads live MCA terms and the Gazette (reply by 15 Dec) — Owner, CS

By 30 Nov 2026

- CERT-In: name a contact, write the 6-hour runbook, keep logs 180 days (aim for 1 year) — Owner, Dev

Before the first live filing

- Guards: no placeholder values; company's own contact details; log filer, DSC holder, device and IP — Dev
- Due-diligence gate in Suite: site-visit evidence, owner NOC, video-KYC, certifier attestation — Dev, CS
- Harden extension updates: force-install, pinned URL, hardware MFA, 2-person release, kill switch — Dev

By 31 Dec 2026

- Ask the PI insurer in writing about tool-assisted filing and cyber; buy a cyber policy if needed — Owner

By 31 Jan 2027

- Engagement letter: tech-assisted preparation, AI use, sub-processor list, client consent — Owner, CS
- Anthropic (if kept): record Terms + DPA, request zero data retention, turn off fallback — Owner, Dev

By 28 Feb 2027

- Move real-data Ask VCFO to Bedrock India: "in." model IDs, retention "none", test rejects global IDs — Dev

By 31 Mar 2027

- Masked Aadhaar only; encrypt PAN; mask names, addresses, phones where not needed — Dev
- Director notice + consent step in the client questionnaire — Dev, CS

By 15 Apr – 13 May 2027

- DPAs with every processor (AWS, Anthropic, Resend, Inngest) — Owner
- Three-clock incident runbook + one tabletop drill — Owner, Dev
- DPDP readiness review — CS, Owner

Every month

- Watch: live MCA terms, s.70 notices, UIDAI rules, DPDP Gazette, Anthropic and AWS terms — CS

CONTEXT

What this changes, and what we could not check

Earlier research vs now

EARLIER POSITION	NOW
Extension on the live portal: Needs CS opinion (terms unreadable)	**Corrected** Terms read (2018 copy); no extension or bot clause. Allowed with conditions; CS sign-off still required.
s.72A penalty unclear (₹5 lakh or ₹25 lakh)	**Resolved** Civil penalty up to ₹25 lakh since Nov 2023.
s.447 figures unverified	**Confirmed** 6 months to 10 years; fine up to 3× the amount.
s.70 protected system not checked	**Narrowed** No MCA21 notification found; Gazette not searchable.
Cross-border transfer under DPDP unclear	**Narrowed** No country restricted; s.16 starts ~May 2027. Live issues: CA confidentiality and SPDI.
DPDP penalty: ₹250 crore only	**Extended** Also ₹200 crore (breach notice) and ₹50 crore (other).
Aadhaar Data Vault applies	**Resolved** Now only for UIDAI requesting entities, not SBC. Keep masked Aadhaar only.
Enforcement targets the certificate, not the tool	**Confirmed** Sharpened by the Feb 2026 dummy-values order.

Changes for the design documents

- SAFETY.md: fix the G9 text (emails and phones are refused, not masked).
- Add a guard: never fill a value missing from the source data.
- G14: log the certifier's own checks, and the DSC holder, device and IP.
- G14: keep logs at least **one year**, not 180 days.
- Add a guard for how the extension itself is updated.
- CS-QUESTIONS.md: fix question 16 (Bedrock region) and add four questions.

Evidence limits

- mca.gov.in and the Gazette blocked access.
- MCA terms read from an official 2018 copy.
- SPDI Rules, Aadhaar s.29, AWS DPA and ICAI's AI note not read in full.
- Anthropic's two retention statements conflict.
- Whether India-only processing works on the endpoint your code uses must be checked in the AWS Mumbai console.
- No court has ruled on attended browser filling.

The bottom line

The extension, which looked like the legal risk, is the most careful tool found on the market. The AI chat inside your own app is the part already exposed today, because of the oldest rule in the profession: do not share a client's affairs without the client's consent. So the next six months are a sequencing problem, not a legal block. **First:** client consent and the CERT-In runbook. **Then:** Bedrock India and director notices before May 2027. **And before any live filing:** a gate in Suite that will not show the Submit card until the certifier's own evidence is attached.

Research, not legal advice. A practising Company Secretary or advocate must read the full report, check its sources and confirm each verdict in writing before live use of VCFO Assist or real-data use of Ask VCFO.